MCP Server Resource Enumeration Vulnerability Report

1. Executive Summary

This vulnerability exists in an MCP (Model Context Protocol) server that exposes internal resources to connected AI clients. The server does not properly enforce authentication before allowing resource enumeration and access.

2. Vulnerability Description

The MCP server accepts unauthenticated initialize requests, and allows listing and reading internal resources without proper session validation. An attacker can directly connect to the MCP endpoint and enumerate all exposed resources.

3. Exploitation Methodology

1. Send an MCP initialize request with the correct protocol version and required Accept headers.
2. List all available resources on the server, including restricted internal resources.
3. Call the unlock tool to unlock restricted resources, then read the sensitive resource content directly.

4. Impact

This allows unauthenticated attackers to enumerate and read all internal MCP resources, including sensitive flags and internal configuration.

5. Remediation Recommendations

Enforce proper authentication on all MCP endpoint requests, and validate session tokens before allowing any resource listing or read operations. Restrict which resources are exposed to external clients.